

SOC Homelab — Master Documentation

Single, synthesized reference for the SOC Homelab project. Current state only — full history and evidence live in the per-topic source docs linked throughout and indexed at the bottom of this file.

Status labels:  verified/current ·  open item, needs action ·  planned, not built.

Table of contents

1. [Project overview & purpose](#)
 2. [Architecture & network design](#)
 3. [Systems in detail](#)
 4. [Architecture, security & AI rules](#)
 5. [Operational guides](#)
 6. [Detection use cases & incident response](#)
 7. [Troubleshooting history](#)
 8. [Project timeline](#)
 9. [Asset inventory](#)
 10. [Glossary](#)
 11. [Current project status / what's next](#)
 12. [Attack scope: agreed Red Team test plan](#)
-

1. Project overview & purpose

SOC Homelab (originally "Fortress Bazzite") is Joost Hebly's private cybersecurity training environment — a real SOC, built and operated end-to-end, including the real problems that come with it.

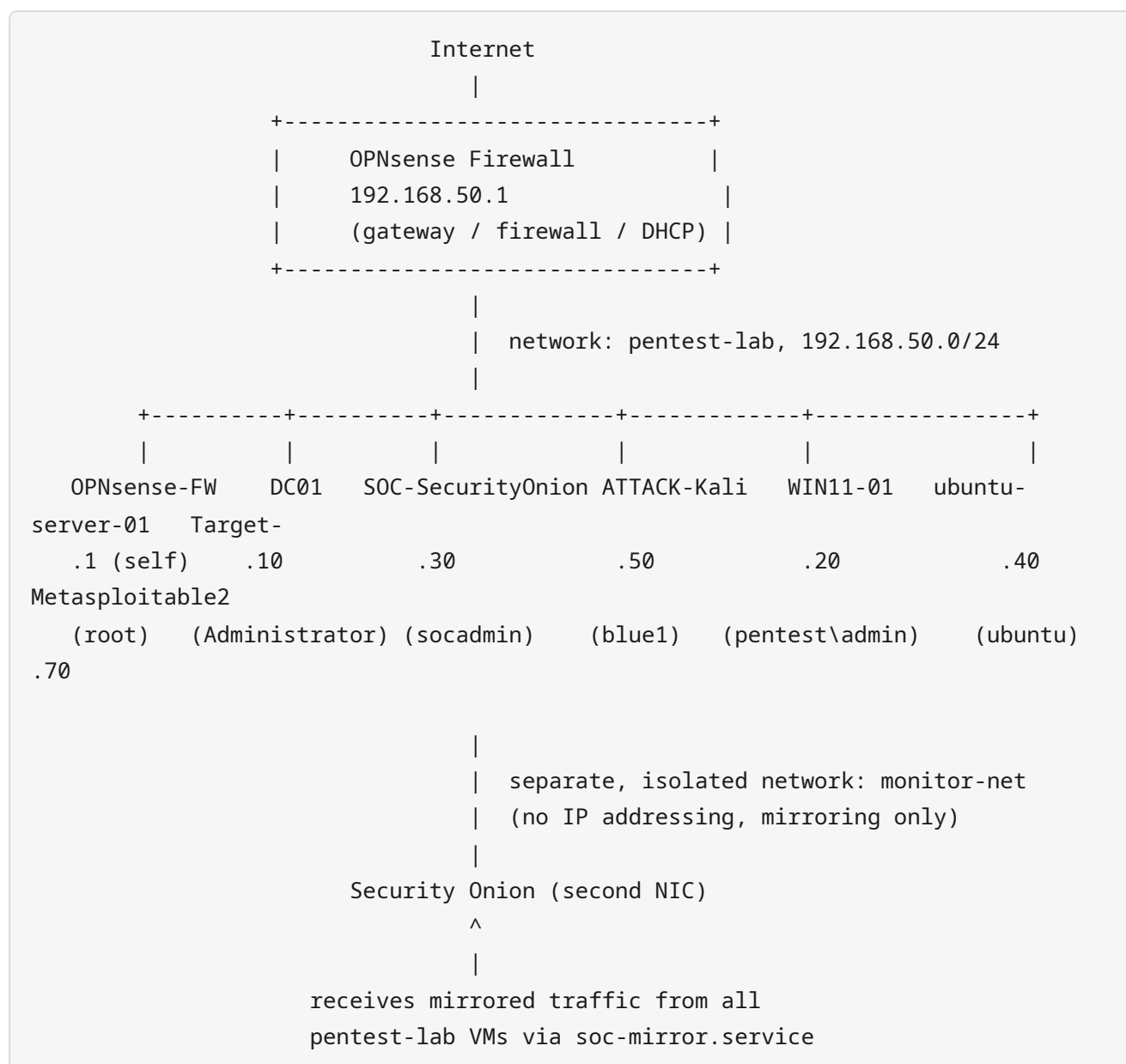
Focus areas: **Blue Team** (Security Onion/Kibana monitoring, incident response, detection engineering), **Red Team** (vulnerability testing, exploitation, AD attacks), realistic **Active Directory**, general **network defense**. Also a portfolio piece — Joost produces formal reports/documentation from it alongside the working lab.

Origin: started as Fortress Bazzite (self-built Suricata+Zeek+Wazuh stack, design doc 2026-07-05). In practice, **Security Onion** was chosen instead — same goal, one bundled platform (it already includes Suricata, Zeek, and Fleet/Elastic Agent in place of Wazuh). Original detection goals carried forward — [§6](#).

AI collaboration: ChatGPT for architecture/planning/strategy, Claude Code for terminal work/documentation/scripts/implementation. Both operate under the AI rules in [§4](#). **Golden rule:** no destructive changes without approval; all changes documented.

2. Architecture & network design

Network map



Security Onion has two NICs: `pentest-lab` (.30, Fleet/Kibana/SSH/web) and `monitor-net` (no IP, mirrored traffic only).

IP address table

IP	System	virsh VM name	SSH alias	SSH user	Status
192.168.50.1	OPNsense (firewall/gateway)	OPNsense-FW	opnsense	root	✓
192.168.50.10	DC01 (AD, PDC Emulator, domain pentest.lab)	DC01	dc01	Administrator	✓
192.168.50.20	WIN11-01 (domain-joined as DESKTOP- EFKB8GQ)	WIN11-01	win11-01	pentest\administrator (key auth confirmed working)	✓
192.168.50.30	Security Onion 3.1.0 (SIEM/IDS/Fleet)	SOC- SecurityOnion	security- onion	socadmin	✓
192.168.50.40	ubuntu-server-01 (live OWASP Juice Shop on :3000)	ubuntu-server- 01	ubuntu- server	sysadmin (key auth confirmed working)	✓
192.168.50.50	Kali Linux (Red Team)	ATTACK-Kali ⚠ <i>leading space in the name</i>	kali	blue1	✓
192.168.50.70	Metasploitable2 (vulnerable target)	Target- Metasploitable2	(none)	—	✓

Known naming bug: the VM name `ATTACK-Kali` has a literal leading space in libvirt (broke name-matching scripts once — [§7](#)). New scripts should match on UUID instead.

IP authority: `Documents/ASSET_INVENTORY.md` and `NETWORK.md` (2026-07-13) are authoritative — older docs and the 2026-07-09 daily report contain now-superseded IPs for Security Onion, Kali, ubuntu-server-01, and Metasploitable2; not repeated here.

Virtual networks (libvirt)

Network	Purpose
pentest-lab	Main network, 192.168.50.0/24, isolated. No libvirt-native DHCP — OPNsense handles this exclusively.
monitor-net	Isolated, no IP addressing, exclusively for traffic mirroring to Security Onion.
default	Standard libvirt network, not used by lab VMs.

Physical host

Bazzite Linux. CPU: Intel Core i9-11900K (8c/1s) · GPU: NVIDIA RTX 3090 · RAM: 62 GiB · WiFi: Intel AX210 (Wi-Fi 6E) · Virtualization: KVM/QEMU/libvirt/virt-manager. All  live-verified. WiFi (AX210) is VFIO-passed through to `ATTACK-Kali` for wireless-pentest work, reconfirmed 2026-07-21 — also confirmed it can't run AP mode on any OS regardless of assignment (hardware/firmware limit), so it's not a candidate for the deferred WiFi-behind-OPNsense project either.  Host-level Docker not reconfirmed — Juice Shop's actual location is `ubuntu-server-01`, not the host.

Since 2026-07-20, this host's own internet traffic also routes through OPNsense (not just the lab's) — the OPNsense-as-primary-router migration, all 4 phases complete. OPNsense's WAN is a macvtap interface on a second physical NIC (`enp5s0`), getting its own DHCP lease from the real KPN router (double-NAT — the KPN Box 14 doesn't support bridge/modem-only mode, confirmed 2026-07-21). A tested one-action rollback (`scripts/network-fallback-to-kpn.sh` , the "KPN-terugval" panic button, also exposed as a dashboard button) forces this host's traffic back onto the direct KPN connection (`enp6s0`) if OPNsense ever has a problem. Full detail: `Documents/decisions/architecture_decisions.md` .

Traffic mirroring (`soc-mirror.service`)

Event-driven (`scripts/soc-mirror.sh` , triggered by a libvirt qemu hook on every VM start/stop) — no polling timer. When a `pentest-lab` VM starts, its traffic mirrors to Security Onion's `monitor-net` interface; stale rules clean up automatically on Security Onion restart. Status: `scripts/soc-mirror.sh --status` .

DNS and DHCP

DHCP: Kea DHCPv4 on OPNsense, LAN interface only. Subnet `192.168.50.0/24` , dynamic pool `.100 — .200` , 7 static reservations (one per lab VM by MAC — the canonical IP plan, see [§9](#)). Option 6 pushes `192.168.50.10` (DC01) as DNS server. Kea DHCPv6 exists but has no interface assigned (inactive). **DNS:** DC01 (AD DNS) authoritative for `pentest.lab` ; OPNsense's Unbound forwards the `pentest.lab` domain specifically to `192.168.50.10` and has one host override (`dc01.pentest.lab → .10`), everything else resolved/forwarded normally. Confirmed 2026-07-13 via a full read-only OPNsense audit — full detail: `Documents/OPNSENSE_AUDIT_2026-07-13.md` .

Security principles

Segmentation (`monitor-net` fully separate from `pentest-lab`) · least privilege (Security Onion hostgroups) · monitor first, block second · every change documented.

Planned network improvements (not yet built)

VLAN segmentation · separate management/attack networks · additional Windows clients · honeypots · more SOC sensors · WiFi behind OPNsense (segmentation/IDS-inspection for Joost's actual home WiFi, scoped 2026-07-21, paused pending dedicated AP hardware — the host's own WiFi can't be reused, see the Physical host note above).

3. Systems in detail

All facts below are live-verified 2026-07-13 unless marked otherwise.

3.1 Bazzite host & virtualization

Physical KVM/QEMU/libvirt/virt-manager host, doubling as Joost's daily desktop. Storage: qcow2 (snapshots, thin provisioning). Basic lifecycle:

```
virsh list --all
virsh start VMNAME
virsh shutdown VMNAME      # graceful; --destroy only if stuck
```

⚠ QEMU guest agent isn't configured by default per VM — install/enable in-guest before relying on guest-management features.

Own Elastic Agent (2026-07-14): the host itself (IP `192.168.50.254` on the `virbr10` / `pentest-lab` bridge — distinct from OPNsense's `.1`) runs a log/metrics-only Elastic Agent (`journald` `system.auth` / `system.syslog` + `system/metrics`, no Elastic Defend by design — this is the machine every VM depends on). Confirmed Healthy/Connected in Fleet, confirmed to survive a full host reboot with zero manual steps. Ingest-side verified end-to-end the same day: a deliberate packet capture (zero TCP resets) plus a targeted Elasticsearch/Hunt query for the exact test window confirmed all 3 test `sudo` events fully indexed with correct field-level detail. An earlier same-day finding that `journald` logs never arrived was itself wrong — a diagnostic-method problem (the Fleet data-streams API doesn't reliably surface this bursty dataset), not a real delivery failure. Full investigation and methodology notes: `Documents/troubleshooting/08_bazzite_host_elastic_agent.md`. Quick health check across this host + all 7 lab VMs: `scripts/soc-health-check.sh`.

3.2 OPNsense (firewall/gateway)

Central firewall/gateway for `192.168.50.0/24` — firewall, routing, DHCP, DNS forwarding. IP `.1`. SSH alias `opnsense`, user `root`, password-only login by design (no key auth configured — confirmed via the OPNsense audit, not a regression). OPNsense `26.1.11_6-amd64` / FreeBSD `14.3`. No custom firewall rules beyond the LAN/WAN defaults (no inter-VM segmentation at this layer), no VPN configured, single local admin user. Full configuration audit: `Documents/OPNSENSE_AUDIT_2026-07-13.md`.

3.3 DC01 — Active Directory Domain Controller

Windows Server 2022 Standard Evaluation. Domain `pentest.lab`, DC01 is PDC Emulator (only DC). IP `.10`. SSH alias `dc01` / `Administrator`. Timezone `W. Europe Standard Time` (cosmetic; UTC clock is authoritative).

AD structure is built (not just planned):

```

DC=pentest,DC=lab
├── OU=Domain Controllers      (DC01)
├── OU=Admins                  (IT Admin 01)
├── OU=AD-Users                (soctest, Helpdesk 01, Employee 01, Manager 01, HR
01, Finance 01)
├── OU=Workstations            (empty)
├── OU=Servers                 (empty)
├── OU=Groups                  (SOC-Analysts: soctest · Helpdesk: no members)
└── OU=Service-Accounts       (SQL Service)

```

⚠ **Known gaps** (real, deliberately left as-is pending [§12](#)): `OU=Workstations` / `OU=Servers` empty (WIN11-01 not moved in); `IT Admin 01` has no elevated group membership despite its name/OU; `Helpdesk` group has no members; role accounts (`Employee/Manager/HR/Finance 01`) are undifferentiated `Domain Users`.

Monitoring: Elastic Agent + Sysmon 15.21 (SwiftOnSecurity config) enrolled in Fleet, **Healthy** — full root-cause history in [§7.6](#). NTP via `pool.ntp.org`; `vmctimesync` disabled (was fighting NTP at boot).

3.4 WIN11-01 — Windows 11 workstation

IP `.20`, SSH alias `win11-01` (`pentest\administrator`, key auth confirmed working — see `Documents/troubleshooting/09_win11-01_ssh_access.md`). Domain-joined as `DESKTOP-EFKB8GQ` (never renamed, still in default `Computers` container). As of 2026-07-13, only TCP 135 was reachable; SMB/RDP/WinRM/139 were blocked by Windows Firewall. As of 2026-07-14, port 22 (SSH) is also open — Joost enabled OpenSSH Server himself via the VM console, a deliberate change, not a regression. Other ports not re-verified this session, assumed unchanged. ⚠ Intended training purpose still undecided beyond "becomes a target after cleanup" — [§12](#).

Monitoring (2026-07-14): Elastic Agent 9.3.3 + Sysmon 15.21 (SwiftOnSecurity config) enrolled in Fleet under the same `endpoints-initial` policy DC01 uses (Windows Event Logs, Sysmon, Elastic Defend, osquery, metrics). **Healthy** — reached that state after Fleet's server-side view lagged the agent's own local status for ~12 minutes post-enrollment, comparable to DC01's documented stabilization delay, not a stuck state. Confirmed in Hunt: ~6,351 total events, ~1,004 `windows.sysmon_operational` events, current activity. Full investigation, including a firewall hostgroup step that was tested and found to be a no-op (not the fix) and a `wsasend` connection-reset message shown to also occur on DC01's healthy agent (so not diagnostic of a fault): `Documents/troubleshooting/10_win11-01_sysmon_elastic_agent.md`.

3.5 ubuntu-server-01 — Linux server, active Red Team target

IP `.40` — confirmed via OPNsense's own Kea DHCP reservation database. Previously seen drifting to `.100` (dynamic pool) after a reboot; **root cause proven and fixed 2026-07-14** (`Documents/troubleshooting/12_ubuntu-server-01_dhcp_reservation_fix.md`) — this Ubuntu image runs two DHCP negotiations per boot (an early dracut-fallback one, then the real netplan one), and without `dhcp-identifier: mac` the second used a non-MAC client identifier that Kea's reservation didn't match. Fixed with one netplan line; validated across a full reboot. SSH alias `ubuntu-`

server / sysadmin (not ubuntu as earlier documented); key auth confirmed working. Elastic Agent installed and Healthy in Fleet (log/metrics-only, same scope as the Bazzite host) —

Documents/troubleshooting/11_ubuntu-server-01_elastic_agent_rollout.md . Runs **OWASP Juice Shop** live on port 3000 (HTTP-confirmed, not a leftover — it's up right now).

3.6 Security Onion — SOC platform

Security Onion 3.1.0 standalone. IP .30 , SSH security-onion / socadmin (key auth works). OS timezone intentionally UTC (web UI already renders local time). Own internal firewall — hostgroups gate portgroups, membership in one grants nothing in another (root cause of the DC01 outage, [§7.6](#); reference: [§5.4](#)). Bundles Suricata, Zeek, Elasticsearch, Kibana, Fleet, Hunt.

3.7 Kali Linux — Red Team workstation

VM ATTACK-Kali (leading space). IP .50 , SSH kali / blue1 (key auth works). Vulnerability scanning, exploitation, network analysis — authorized use inside this isolated lab only.

3.8 Metasploitable2 — vulnerable training target

VM Target-Metasploitable2 . IP .70 . Stock, unmodified port fingerprint confirmed (FTP/SSH/Telnet/SMTP/DNS/HTTP/rpcbind/SMB/rexec-rlogin-rsh/Java-RMI/ingreslock/NFS/ProFTPD-backdoor/MySQL/distccd/PostgreSQL/VNC/X11/UnrealIRCd/AJP/Tomcat). No ACPI shutdown support — lab-stop.sh force-stops it after 60s (expected).

4. Architecture, security & AI rules

Why these technologies were chosen

Decision	Choice	Core reason
Host OS	Bazzite Linux	Modern Linux + NVIDIA + gaming + virtualization on one machine
Virtualization	KVM/QEMU/libvirt/virt-manager	Native Linux, full control, deeper understanding than a turnkey hypervisor
Firewall	OPNsense	Realistic enterprise firewall/routing/DHCP/DNS practice
SOC platform	Security Onion	Complete SIEM+IDS+NSM bundle, superseding a hand-rolled stack
Identity	Windows Server AD (DC01)	Realistic detection/attack scenarios (logins, privilege escalation, lateral movement)
Version control	Git	History, recovery points, professional change tracking
Secrets storage	Separate <code>Secure/SOC-Secure.img</code> , never in Git	Docs can be shared; secrets must never enter Git history
AI assistance	ChatGPT (planning) + Claude Code (implementation)	Support tools, not decision-makers — bound by the rules below

AI rules (binding on any AI assistant working on this project)

Merged from `AI_ACCESS_POLICY.md`, `PROJECT_RULES.md`, `CLAUDE.md`. Claude Code acts as a **junior SOC engineer and documentation assistant**, not an autonomous administrator — documentation is treated as more reliable than its own memory; source of truth: `README.md`, `PROJECT_RULES.md`, `AI_ACCESS_POLICY.md`, `Documents/INDEX.md`, `Documents/guides/`, `Documents/troubleshooting/`, `Documents/decisions/`.

Allowed: read/analyze documentation and configs, explain commands, suggest improvements, write/maintain documentation, troubleshoot (research, diagnosis, proposing fixes). AI assists — it doesn't replace administrator decisions.

Never: store or write down passwords/secrets/API keys/private keys/tokens anywhere; commit credentials; modify firewall rules or critical infrastructure without approval; delete or destructively change anything without confirmation; ignore previous documented decisions.

Credentials: never in Git or markdown, not even temporarily. Live only in `Secure/SOC-Secure.img`, opened manually by the administrator — an assistant never touches it. The user enters passwords themselves when needed.

Infrastructure change procedure: explain what will change → explain risk/impact → snapshot/backup → get explicit confirmation → execute the smallest sufficient change → document the result.

Troubleshooting method: check existing docs → identify the affected system → review prior troubleshooting cases → explain root cause → apply the smallest safe fix → update documentation.

General behavior: respect prior decisions, preserve existing architecture, ask before destructive (even reversible) actions, document discoveries as they happen, prefer safe/reversible solutions, explain commands and verify results rather than assuming success.

Read-only investigation is in-scope without prior confirmation — e.g. using `virsh`, ARP tables, unauthenticated port probes, or already-working passwordless SSH to verify facts for documentation. Anything that *changes* the lab (firewall, AD objects, service state) still needs the full change procedure above.

Final principle: documented, reproducible, secure, understandable — documentation first, automation second, security always.

Core security principles

Least privilege · defense in depth (OPNsense + Security Onion hostgroups + host controls) · network isolation (192.168.50.0/24 is isolated because it hosts attack tooling and deliberately vulnerable machines) · documentation before/with automation · backups before changes · monitoring as the foundation, not an add-on · all offensive testing stays inside the lab boundary.

Incident response phases

Identification → Analysis → Containment → Recovery → Lessons learned. Operationalized in the runbook — [§6.2](#).

5. Operational guides

5.1 Starting/stopping the lab

Preferred: **Pentest Lab Start / Stop** desktop launchers (all 7 VMs, correct order). Command line:

```
~/Homelab/scripts/lab-start.sh
~/Homelab/scripts/lab-stop.sh
```

Single VM: `virsh -c qemu:///system start|shutdown <vm-name>` — note the leading space in `ATTACK-Kali` ([§9](#)). `lab-start.sh` is idempotent; `lab-stop.sh` tries graceful ACPI shutdown first (60s/180s timeout) before force-killing.

5.2 Connecting to systems

SSH Alle Machines launcher opens one Konsole tab per machine, or directly:

```
ssh opnsense
ssh dc01
ssh security-onion
ssh kali
ssh ubuntu-server
ssh win11-01
```

Homelab VM Manager opens virt-manager on `qemu:///system`. **Key status:** `kali`, `security-onion`, `dc01`, `ubuntu-server`, and `win11-01` are all passwordless; only `opnsense` still prompts (password-only by design, not a regression — see [§9](#)).

5.3 Security Onion / Kibana / Fleet in the browser

Security Onion Operator launcher opens a persistent Playwright/Chromium profile with every key page as a tab (Overview, Hunt, Detections, Cases, Grid, Kibana, Fleet), driven via a local CDP port (never exposed beyond localhost). First run waits for manual login to both Security Onion and Kibana/Fleet (two separate logins); session persists in `browser/profile/` (never in Git). Everything built so far is **read-only** — nothing can modify Fleet, detection rules, or Security Onion config.

Fleet status report: `~/Homelab/scripts/soc-web-audit.sh` → Markdown report in `browser/artifacts/`.

⚠ Recorded incident: a script once printed a live session cookie into terminal output via a raw `context.request` call. No external leak, but fixed immediately (daemon restarted, session invalidated) and all API calls now route through `fetchJsonInPage()`, which runs inside the authenticated page so cookies never pass through this project's own code. Don't reintroduce raw out-of-page HTTP calls without the same care.

5.4 Network ports & firewall hostgroups reference

Security Onion's **own** firewall (separate from OPNsense) — reconstructed from `/opt/so/saltstack/default/salt/firewall/{defaults,soc_firewall}.yaml`.

Portgroup	Port(s)	Purpose
elastic_agent_control	8220	Fleet Server checkin
elastic_agent_data	5055	Data ingest
elastic_agent_update	8443	Agent updates
endgame	3765	Elastic Defend/Endpoint output
beats_5044 / 5644 (SSL) / 5066 / 5056	—	Logstash beats input
kibana	5601	Kibana web UI
elasticsearch_rest	9200	Elasticsearch REST

Key hostgroups: `analyst` (web UI/Kibana users) · `elastic_agent_endpoint` (Fleet checkin) · `beats_endpoint` / `_ssl` (log shipping) · `endgame` (Elastic Defend) · `manager` / `receiver` / `sensor` / `standalone` (grid roles) · `desktop` (admin workstations, like `analyst` plus extras).

A normal endpoint with Elastic Agent needs *all three of* `elastic_agent_endpoint`, `beats_endpoint`, and `endgame` — `analyst` alone is not enough; one hostgroup grants nothing in another.

```
sudo so-firewall includehost <hostgroup> <ip>
sudo so-firewall apply          # additive; so-firewall removehost <ip> to strip
entirely
```

Read-only inspection: `cat /opt/so/log/so-firewall.log`, `ss -tlnp`. From another host: `Test-NetConnection -ComputerName 192.168.50.30 -Port 8220`.

5.5 Desktop launchers

Launcher	Purpose
Pentest Lab Start / Stop	Start/stop all 7 VMs in order, via Konsole (<code>--hold</code>)
SSH Alle Machines	One Konsole window, independent tab per machine
Homelab VM Manager	virt-manager on <code>qemu:///system</code>
Security Onion Operator	Persistent browser session — §5.3
KPN Terugval	Panic button (2026-07-20) — forces this host's internet back onto the direct KPN connection if OPNsense ever has a problem; runs <code>scripts/network-fallback-to-kpn.sh</code> via Konsole. Also available as a button on the SOC Alarmdashboard itself.

Bazzite has no `gnome-terminal` — all terminal launchers use Konsole specifically.

SSH config (`~/.ssh/config`):

Alias	Host	User	Status
<code>opnsense</code>	<code>.1</code>	<code>root</code>	Password-only, currently not even password-prompting reliably
<code>dc01</code>	<code>.10</code>	<code>Administrator</code>	Key auth works
<code>security-onion</code>	<code>.30</code>	<code>socadmin</code>	Key auth works
<code>kali</code>	<code>.50</code>	<code>blue1</code>	Key auth works
<code>ubuntu-server</code>	<code>.40</code>	<code>sysadmin</code>	Key auth confirmed working (2026-07-14)
<code>win11-01</code>	<code>.20</code>	<code>pentest\administrator</code>	Added 2026-07-14, key auth confirmed working (see <code>Documents/troubleshooting/09_win11-01_ssh_access.md</code>)

5.6 Quick reference

```
# Sysmon test event on DC01, then check Hunt (Last 15 Minutes):
# host.name:"dc01" AND event.dataset:"windows.sysmon_operational"
Start-Process -FilePath 'cmd.exe' -ArgumentList '/c echo test' -Wait

~/Homelab/scripts/soc-mirror.sh --status # mirroring status
ssh security-onion "tail -20 /opt/so/log/so-firewall.log"
```

6. Detection use cases & incident response

6.1 What this SOC should detect

✅ present (works once traffic/logs arrive) · ⚠️ should work via default rulesets, not yet deliberately confirmed · ❌ needs custom rules, not built.

Detection	Status
ICMP ping sweeps / TCP scans (SYN/FIN/NULL/XMAS) / UDP scans	✅ Confirmed 2026-07-15 — see Metasploitable2 Tier 1 scan below
OS fingerprinting / banner grabbing	✅ Confirmed 2026-07-15 — see Metasploitable2 Tier 1 scan below
SSH / FTP / SMB brute force	⚠️ (SMB relevant especially toward DC01)
AD / LDAP / SMB enumeration	✅ Confirmed 2026-07-15 — see "DC01 Tier 1 AD enumeration" below. Deliberately a separate row from brute force: enumeration (single null-session/anonymous-bind probes reading directory/share structure) and brute force (repeated authentication attempts against credentials) are different behaviors with different signatures, and shouldn't be collapsed into one row.
Suspicious DNS requests	⚠️ (Zeek <code>dns.log</code> ; Sysmon event 22 on DC01)
Known exploit signatures / reverse shells / Metasploit indicators	✅ Confirmed 2026-07-15, with an important nuance — see "Metasploitable2 Tier 2 exploitation" below
SQLi / command injection / directory traversal	⚠️ (Suricata web-attack rulesets)

Metasploitable2 Tier 1 scan — TCP scans + OS fingerprinting/banner grabbing, confirmed 2026-07-15:

- **Command:** `nmap -sV -sC -p- 192.168.50.70` (full 65535 TCP ports, service/version detection, default NSE scripts).
- **Source:** ATTACK-Kali (`192.168.50.50` , run via SSH from the Bazzite host). **Target:** Metasploitable2 (`192.168.50.70`).
- **Time window:** `2026-07-15 01:50:48Z – 01:53:20Z` (scan itself: `01:50:54Z – 01:53:10Z` , 136.31s per nmap's own summary).
- **Result:** 30 open ports found (vsftpd 2.3.4 with anonymous login, telnet, Postfix smtpd, BIND 9.4.2, Apache 2.2.8, unauthenticated NFS/RPC, Samba 3.0.20, rexecd, a literal "Metasploitable root shell" bindshell on 1524, MySQL 5.0.51a, distccd, PostgreSQL 8.3, VNC, UnrealIRCd, Tomcat, Ruby DRb) — matches this target's known stock fingerprint.
- **Hunt evidence, same source/dest/window:**
 - `event.dataset:"zeek.conn" / zeek.weird : 65,801 events` — confirms full network-level visibility of the scan traffic (query: `source.ip:"192.168.50.50" AND destination.ip:"192.168.50.70" AND @timestamp:[2026-07-15T01:50:40.000Z TO 2026-07-15T01:53:20.000Z]`).
 - `event.module:"suricata"` , same source/dest/window: **172 real alerts**, not raw traffic — signature-based detections firing on the actual scan. Distinct signatures observed: `ET SCAN Potential SSH Scan OUTBOUND` (medium), `ET SCAN Suspicious inbound to PostgreSQL port 5432` (medium), `ET SCAN Suspicious inbound to mySQL port 3306` (medium), `GPL DNS named version attempt` (medium — fired by `-sC`'s `dns-nsid` script, a direct banner-grab signature), `GPL NETBIOS SMB-DS IPC$ share access` (low — fired by the `SMB/ smb-os-discovery` enumeration scripts).

- **Why this flips both rows:** ET SCAN Potential SSH Scan OUTBOUND and the PostgreSQL/MySQL "suspicious inbound" signatures are pattern-based scan detections that fired directly on this `-p-` full-port sweep — confirms **TCP scan detection** works, not just default-ruleset assumption. GPL DNS named version attempt and the SMB share-access/ smb-os-discovery signature are specifically banner-grab/service-fingerprinting detections, triggered by nmap's own `-sC` scripts querying BIND's version and enumerating SMB — confirms **OS fingerprinting/banner grabbing detection** works, not just passive Zeek visibility as previously assumed.

Host-based (Sysmon on DC01): Process Create (1), Network Connection (3), File Create (11), DNS Query (22) — all  confirmed with test events. Other event types (registry, image load) —  covered by config, not individually tested. Elastic Defend also produces its own detections since the 2026-07-13 firewall fix.

How to test (Purple Team style): run a harmless version of the technique from Kali, check Security Onion Hunt/Detections. Example:

```
for i in 1 2 3 4 5; do ssh -o ConnectTimeout=3 -o BatchMode=yes
nope@192.168.50.40; done
# Hunt: destination.ip:"192.168.50.40" AND event.dataset:*ssh*
```

6.2 Incident response runbook

Fixed procedure for any alert — real, test, or exercise:

1. **Confirm** — Security Onion Alerts/Detections: which rule, source/destination, when (SO shows local time, +02:00 summer), how often.
2. **Context** — Hunt: `source.ip:"<IP>" OR destination.ip:"<IP>"` . Known lab system ([§9](#))? Deliberate test running (`Documents/daily/`)? Anything else at that time?
3. **Host check** (if SSH-reachable) — logs/processes, Sysmon events around the timestamp. Investigating is always fine independently; changing/restarting/isolating needs a quick explanation first unless already agreed.
4. **Record** — write up in `Documents/daily/YYYY-MM-DD/rapport.md` regardless of outcome; genuine new technical problems also get a `Documents/troubleshooting/` doc.
5. **If real** — don't panic (lab is isolated); consider isolating via `virsh` (explain first); preserve evidence before cleanup; document as step 4.

Quick Hunt queries: `host.name:"<lowercase-name>" . ... AND event.module:"windows" . ... AND event.dataset:"windows.sysmon_operational" . source.ip:"<ip>" OR destination.ip:"<ip>"` .  Hostnames index lowercase (`dc01`), even though Fleet displays capitalized.

6.3 Detection validation plan

In progress — [§12](#) test session started 2026-07-15 (Phase 3 of the project roadmap). Every  in [§6.1](#) gets tested here rather than in a separate pass: Tier 1 (recon) covers scans/sweeps/fingerprinting/DNS; Tier 2 (Metasploitable2/Juice Shop exploitation) covers brute force,

exploit signatures, reverse shells, Meterpreter, SQLi/injection; Sysmon "other" event IDs get tested on DC01 or WIN11-01 once it's a target. Method: run technique → check Hunt → flip 🚩 to ✅/❌ with the query and evidence used. Also planned: one full runbook dry-run (§6.2) against a real alert from that pass, logged in `Documents/daily/`.

Tier 1 progress:

Scenario	Status	Evidence
Full port/service scan — Metasploitable2	✅ Done, 2026-07-15	See §6.1 "Metasploitable2 Tier 1 scan" — 172 Suricata alerts, 65,801 Zeek events, flipped 2 rows to ✅
Web app recon — Juice Shop (nikto, gobuster / ffuf)	✅ Done, 2026-07-15	See "Juice Shop Tier 1 web recon" below — 3,637 Suricata alerts, no §6.1 row flipped outright (see notes)
AD/domain enumeration — DC01 (enum4linux-ng, netexec smb, anonymous LDAP)	✅ Done, 2026-07-15, read-only only	See "DC01 Tier 1 AD enumeration" below — 3 Suricata alerts incl. a high-severity anonymous-LDAP-bind signature; flipped a new §6.1 row, "AD / LDAP / SMB enumeration," to ✅
Network sweep (.0/24)	✅ Already done (nmap -sn , confirmed known IPs only, per §12 "Preparation already done")	—

Juice Shop Tier 1 web recon — confirmed 2026-07-15:

- **Commands:** `nikto -h http://192.168.50.40:3000` (8,907 requests, 95s, 25 items reported), then `gobuster dir -u http://192.168.50.40:3000 -w /usr/share/wordlists/dirb/common.txt --exclude-length 9903` (the Juice Shop SPA returns HTTP 200 for any unmatched path — length-excluded to filter that wildcard).
- **Source:** ATTACK-Kali (192.168.50.50). **Target:** ubuntu-server-01 / Juice Shop (192.168.50.40:3000).
- **Time window:** 2026-07-15 01:58:31Z – 02:01:09Z (nikto 01:58:34 – 02:00:09Z ; gobuster 02:00:14 – 02:01:09Z , back-to-back, both timestamped independently).
- **Nikto findings:** exposed `.bash_history` / `.sh_history` / `.htpasswd` -shaped paths, several `*.json` endpoints ("might be interesting"), a `x-recruiting` header, missing CSP/referrer-policy/HSTS headers — informational web-hygiene findings, not a Suricata-detection test in themselves.
- **Gobuster findings:** real endpoints confirmed — `/api` , `/rest*` , `/assets` , `/media` , `/promotion` , `/ftp` , `/robots.txt` , plus an oddity worth a separate look later (`/Video` and `/video` both returning a 2.2 MB body).
- **Hunt evidence, same source/dest/window, port 3000: 4,557 total events**, of which **3,637 are real Suricata alerts** (`event.module:"suricata"`), not raw traffic. Distinct signatures: `ET EXPLOIT QNAP Shellshock CVE-2014-6271` (**high**, Attempted Administrator Privilege Gain — nikto's Shellshock-probe header), `GPL WEB_SERVER iisadmin access` (**high**, Web Application Attack), `ET WEB_SERVER WEB-PHP phpinfo access` , `GPL WEB_SERVER global.asa access` ,

GPL WEB_SERVER printenv access , GPL WEB_SERVER /~root access , ET WEB_SERVER Possible Cherokee Web Server GET AUX Request DoS Attempt , ET INFO Proxy TRACE Request - inbound , ET INFO Dotted Quad Host DLL Request .

- **Why no §6.1 row is flipped outright:** these signatures are mostly nikto's own vulnerability-probe requests and gobuster's wordlist entries coincidentally matching legacy CGI/PHP/IIS signature paths — real detections, but not a clean match for any existing §6.1 row. The Shellshock signature is the closest (ET EXPLOIT . . .), but "Known exploit signatures / reverse shells / Metasploit indicators" also explicitly covers reverse-shell/Meterpreter indicators, which are untested here (Tier 2 scope, not yet approved) — flipping that row fully would overclaim based on this evidence alone. Recorded as strong supporting evidence for that row once Tier 2 actually tests exploitation.

DC01 Tier 1 AD enumeration — confirmed 2026-07-15, read-only only:

- **Commands:** `enum4linux-ng -A 192.168.50.10` (full read-only sweep: SMB dialects, null-session domain info, RPC users/groups/shares/policy/printers), `netexec smb 192.168.50.10 --shares` (anonymous share enum), `ldapsearch -x -H ldap://192.168.50.10 -b "dc=pentest,dc=lab" -s base` (anonymous LDAP bind). No credentials used anywhere, no write/modify operation attempted.
- **Source:** ATTACK-Kali (192.168.50.50). **Target:** DC01 (192.168.50.10).
- **Time window:** 2026-07-15 02:04:46Z – 02:05:05Z .
- **AD-side result — DC01 correctly rejected enumeration:** null-session SMB connected and revealed only basic domain identity (NetBIOS name DC01 , domain PENTEST / pentest.lab , domain SID) — every actual enumeration call (`querydispinfo` , `enumdomusers` , `enumalsgroups` , `enumdomgroups` , share list, policy, printers) returned STATUS_ACCESS_DENIED . `netexec` confirmed null-auth accepted at the protocol level but got STATUS_USER_SESSION_DELETED on share enumeration. Anonymous LDAP bind was rejected outright (`Operations error` — "a successful bind must be completed"). This is a real, confirmed security posture, not assumed.
- **Hunt evidence, same source/dest/window:** 76 total events; **3 real Suricata alerts** (`event.module:"suricata"`): ET INFO NTLM Session Setup Request - Auth (low), ET INFO NTLM Session Setup Request - Negotiate (low), and **ET INFO Anonymous LDAPv3 Bind Request Outbound (high, "Potential Corporate Privacy Violation")** — a purpose-built signature that fired precisely on the anonymous LDAP bind attempt.
- **New §6.1 row added, 2026-07-15: "AD / LDAP / SMB enumeration," status .** None of the original 6 rows was a clean match — closest was "SSH/FTP/SMB brute force," but that implies repeated authentication attempts against credentials, not single null-session/anonymous-bind probes reading directory/share structure. These are different behaviors with different signatures (ET INFO Anonymous LDAPv3 Bind Request Outbound / NTLM Session Setup vs. e.g. repeated-failed-logon signatures) and belong in separate rows, not collapsed into one — Joost's explicit decision, not a unilateral restructure.

Tier 1 complete as of 2026-07-15 — all three planned scenarios (Metasploitable2 full-port scan, Juice Shop web recon, DC01 read-only AD enumeration) executed and validated in Hunt with direct evidence.

Tier 2 explicitly approved by Joost, 2026-07-15 ("test tier 2 met mijn toestemming") — execution started the same day, one scenario at a time per `[[feedback_phase3_attack_testing_discipline]]`.

Scenario	Status	Evidence
vsftpd 2.3.4 backdoor — Metasploitable2	✅ Done, 2026-07-15	See "Metasploitable2 Tier 2 exploitation" below — real root RCE achieved, nuanced detection result
Samba/NFS/RMI — Metasploitable2	⌚ Not yet run	—
OWASP Top 10 — Juice Shop	⌚ Not yet run	—
UnrealIRCd backdoor — Metasploitable2	⌚ Not yet run	—

Metasploitable2 Tier 2 exploitation — vsftpd 2.3.4 backdoor (CVE-2011-2523), confirmed 2026-07-15:

- **Technique:** the classic vsftpd 2.3.4 malicious-backdoor RCE — repeats the exact exploit already noted in §8 as done once before, outside this documentation trail. First attempted via `msfconsole` (`exploit/unix/ftp/vsftpd_234_backdoor`), which triggered the backdoor correctly (its own console output confirmed `Backdoor has been spawned!`) but didn't cleanly hand control to a Metasploit session due to a payload/session-handler mismatch in this Metasploit version. Reading the module's own source (`/usr/share/metasploit-framework/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb`) showed the exact underlying mechanism: send `USER <random>:` (a smiley in the FTP username is the trigger), then `PASS <random>` , then connect directly to TCP/6200 for a root shell. Reimplemented that sequence directly in a small Python script for a clean, transparent demonstration, run three times total (two earlier via the `msfconsole` attempts, one final clean manual run).
- **Source:** ATTACK-Kali (`192.168.50.50`). **Target:** Metasploitable2 (`192.168.50.70`).
- **Result — real root code execution, all three attempts:** `id` → `uid=0(root) gid=0(root)` , `whoami` → `root` , `uname -a` → `Linux metasploitable 2.6.24-16-server ... i686 GNU/Linux` , `hostname` → `metasploitable` . No files modified, no persistence installed, no pivoting attempted — read-only recon commands only, consistent with this project's lab-exploitation scope.
- **Detection result — nuanced, both halves independently confirmed in Hunt:**
 - **The exploit trigger itself (FTP `USER x:`) / `PASS x` , then the connection to 6200) was NOT detected.** `event.module:"suricata"` for `source.ip:"192.168.50.50"` AND `destination.ip:"192.168.50.70"` in the exact exploit windows returns zero hits — only Zeek `conn / weird ( active_connection_reuse` , an artefact of the rapid back-to-back connections) logged the traffic at all. No ET/GPL signature exists in this ruleset for the vsftpd-backdoor trigger sequence specifically.
 - **The post-exploitation confirmation WAS detected, all three times.** `GPL ATTACK_RESPONSE id check returned root` fired on the *reverse-direction* traffic (`source.ip:"192.168.50.70"` port 6200 → `destination.ip:"192.168.50.50"` , medium severity, category "Potentially Bad Traffic") at `11:48:21.761Z` , `11:48:50.650Z` , and `11:53:46.630Z` — each timestamp lines up exactly with an `id` command's root-output response crossing the wire. This is a generic content-inspection signature (it looks for `uid=0(root)` appearing in any TCP response, not a vsftpd-specific rule) — it would fire on *any* technique that causes root `id` output to traverse the network, not just this one.

- **Why this flips the §6.1 row, with a caveat:** the row asks about "known exploit signatures / reverse shells / Metasploit indicators" broadly, and a real, reproducible signature did fire on real successful exploitation, three times, with second-level timestamp precision. But it's honest to note this is **detection of the symptom (a root shell responding), not the specific exploit** — a more targeted attacker who avoided ever running `id` (or similar output-leaking commands) over that particular connection would not have tripped this signature. This is a genuine, useful, but narrow detection — not a dedicated vsftpd-backdoor rule. Recorded as a real capability, not overclaimed as complete coverage.
- **SOC Alarmdashboard cross-check:** the same `GPL ATTACK_RESPONSE id check returned root` alerts also appeared in the live alarm dashboard, bucketed as `SCAN` (via the generic "potentially bad traffic" category-text fallback) — arguably a better fit for `EXPLOIT` given it's literally a post-compromise confirmation, not reconnaissance. Not changed in this pass to avoid re-iterating the categorizer without being asked; flagged here for a future categorization refinement.

Tier 2 continues with the remaining three scenarios (Samba/NFS/RMI, Juice Shop OWASP Top 10, UnreallRCd backdoor), one at a time. **Tier 3 remains explicitly out of scope without new, separate explicit approval.**

7. Troubleshooting history

Real problems from building this lab. Full evidence/commands/rollback steps live in `Documents/troubleshooting/0N_*.md` — this is the summary.

#	Problem	Root cause	Fix / lesson
7.1	QEMU guest agent not configured	Not installed/enabled in-guest, channel not configured	Install + enable + configure channel. Lesson: a running VM ≠ working guest integration — test explicitly.
7.2	virt-manager VM setup	Storage/display quirks	Standardized on qcow2; SPICE issues traced to guest tooling, not hardware. Snapshot before risky changes.
7.3	OPNsense network debugging	Firewall issues masquerading as app/DNS problems	Verify bottom-up: interface → IP → gateway → DNS → firewall. DNS misconfig was repeatedly the real AD root cause.
7.4	Security Onion installation	Under-provisioned resources	SOC platforms need materially more RAM/CPU/storage than an ordinary server. A SOC is only as useful as the telemetry reaching it.
7.5	DC01 AD setup	—	DNS is the foundation AD depends on. Snapshot before promoting to DC (hard to cleanly undo).
7.7	soc-mirror.sh libvirtd deadlock	Synchronous virsh callback from inside a libvirt qemu hook could hang libvirtd	Detached the reconciler via <code>systemd-run --no-block --collect</code> .
7.8	libvirt/OPNsense DHCP conflict (2026-07-09)	libvirt's own DHCP collided with OPNsense's; virbr10 claimed OPNsense's own IP	Stripped libvirt's <code><ip></code> / <code><dhcp></code> from the network definition — OPNsense is sole DHCP/DNS/gateway authority. Host got a separate mgmt IP (.254) restored at boot.
7.9	virbr10 bridge-port loss during OPNsense cutover (2026-07-20)	nmcli connection up virbr10 fully reactivates an NM bridge-type connection, which rebuilds it from NM's own port list — libvirt's dynamically-attached VM taps aren't in that list, so every VM (incl. OPNsense) silently lost its bridge port	Restart affected VMs so libvirt recreates the taps. Hard rule going forward: never nmcli connection up/down on virbr10 (or any NM connection that's also a libvirt-managed bridge) — use modify + device reapply instead , which updates IP/route config live without rebuilding the bridge. See §7.9 below and <code>Documents/decisions/architecture_decisions.md</code> .

7.6 DC01 Fleet health & Sysmon telemetry (2026-07-13)

The largest case — three independent, stacked root causes behind one symptom ("DC01 Offline in Fleet"). Recurring: a 2026-07-10 "fix" was a non-persistent `iptables` rule that any `so-firewall apply /reboot` silently discarded.

1. **Firewall hostgroups** — DC01 was only ever added to `analyst`, never `elastic_agent_endpoint` / `beats_endpoint` / `endgame` (each hostgroup only grants its own ports — see §5.4). Fixed with `so-firewall includehost` for all three (additive), `so-firewall apply`.
2. **~9h clock skew** — `vmictimesync` was fighting NTP at every boot (DC01, as PDC Emulator, doesn't behave like an ordinary NTP client). Disabled the service, forced `w32tm /resync`, added a boot-time scheduled task. Side effect: the skew had poisoned Logstash's dead-letter queue with rejected future-timestamped events — explains why `HEALTHY`-reporting agents still showed no data. **Lesson: agent- `HEALTHY` proves shipping, not acceptance.**
3. **Sysmon never installed** — Fleet policy expected `windows.sysmon_operational` data that could never arrive. Installed Sysmon 15.21 + SwiftOnSecurity config.

Verified: survives Elastic Agent restart, two DC01 reboots, and a full Security Onion reboot. Rollback procedures (firewall/clock/Sysmon/timezone) kept in `Documents/troubleshooting/06_dc01_fleet_health_and_sysmon.md`, not repeated here.

General lessons: a "Healthy" status can hide multiple stacked root causes — validate across a real reboot, not just current state. Per-hostgroup firewall reachability doesn't generalize across ports. PDC Emulators aren't ordinary NTP clients.

7.9 `virbr10` bridge-port loss during OPNsense cutover (2026-07-20)

Phase 4 of the OPNsense-as-primary-router migration (routing this host's own default traffic through OPNsense, not just the lab's) needed the host's `virbr10` connection re-pointed at OPNsense's LAN gateway. The first attempt (`nmcli connection modify virbr10 ipv4.gateway ...; nmcli connection up virbr10`) caused **every lab VM, including OPNsense itself, to lose its bridge port on `virbr10` simultaneously** — the whole lab went unreachable from this host for several minutes.

Root cause: `virbr10` is a full NetworkManager `bridge`-type connection, while libvirt independently attaches each VM's tap interface to that same kernel bridge, outside NM's knowledge. `nmcli connection up` fully reactivates the connection, which rebuilds the bridge from NM's own recorded port list — a list that never included libvirt's dynamically-attached taps. This had never surfaced before because the connection had been active, undisturbed, since boot; this was the first time anything explicitly reactivated it.

Recovery: confirmed the whole lab was down (not just this host's route), found the bridge had zero attached ports (`ip link show type bridge_slave`), restarted every affected VM one by one (OPNsense first) so libvirt recreated fresh taps — `Target-Metasploitable2` needed a forced `virsh destroy` (no ACPI shutdown support). Also found and fixed a second, unrelated bug this incident exposed: two duplicate NetworkManager `virbr10` connection profiles (same name, different UUIDs, one stale/disabled) were silently confusing name-based `nmcli` commands — fixed by addressing profiles by UUID from then on.

The fix pattern, now a hard rule: never call `nmcli connection up|down` on `virbr10` (or any NM connection that's also a libvirt-managed bridge). Use `nmcli connection modify <uuid>` to stage a change, then `nmcli device reapply <device>` to push it live — `reapply` updates IP/route config on an already-active device without rebuilding it. `scripts/network-fallback-to-kpn.sh` (the migration's own panic button) follows this rule explicitly. Joost's own internet (`enp6s0`) was never actually affected throughout — only the lab was down, confirmed repeatedly via `curl` .

Full detail: `Documents/decisions/architecture_decisions.md` , "Build the Rollback Path Before Any OPNsense-as-Primary-Router Migration Step" (Phase 4 section).

8. Project timeline

Period	What happened
Before 07-05	Fortress Bazzite: virt-manager, Kali/Debian, Ubuntu Server, Metasploitable2, Docker, Juice Shop, Burp Suite, Metasploit set up. Design doc planning a Suricata+Zeek+Wazuh stack.
07-03 – 07-07	Kali/Metasploitable2 VMs up, <code>pentest-lab</code> network built. Metasploitable2 enumerated and exploited (<code>vsftpd_234_backdoor</code> → Meterpreter). Juice Shop deployed, first vuln found via Burp Suite. AX210 WiFi passed through to Kali. Host-level Suricata installed as a side experiment (<code>/var/home/Joost/FORTRESS/</code> , separate from this repo). OPNsense installed 07-07 (redone with ZFS after a failed first attempt); WAN/DHCP issues left open.
07-08	Transition to "SOC Homelab" naming ( reconstructed from limited evidence).
07-09	First git commit. Fixed libvirt/OPNsense DHCP conflict (§7.8); Kea DHCP reservations created; launchers fixed for KDE/Konsole.
07-10	DC01 built (AD DS + DNS, promoted, users created), enrolled in Fleet. First Fleet issue "fixed" non-persistently (see §7.6).
07-11	Full documentation structure created (README, rules, AI policy, network/server/AD docs, troubleshooting history).
07-12	Secret scrubbed from git history. Desktop launchers rebuilt properly. Traffic mirroring rewritten (deadlock fix). Browser automation for Security Onion built.
07-13	DC01 Fleet outage fully resolved. Live lab verification pass (IPs, AD structure, hardware). Documentation substantially expanded, including this master document, its AI-rules and attack-scope sections. Commit made, not pushed (standing instruction: no push without explicit permission).
07-14	Read-only OPNsense audit. Elastic Agent rolled out to the Bazzite host itself (reboot-resilience verified x2) and to WIN11-01 (+ Sysmon, SSH integrated) and ubuntu-server-01. ubuntu-server-01's long-standing <code>.100</code> -drift DHCP bug root-caused and fixed (MAC-based <code>dhcp-identifier</code> , see [§7.8-adjacent]).
07-15	Endpoint-monitoring phase closed (Kali deliberately excluded). Phase 3 detection-engineering Tier 1 (recon) fully validated in Hunt. Standing rule adopted: snapshot before every Tier 2/3 exploit, restore after. Phase 3 Tier 2 started (vsftpd 2.3.4 backdoor, real root RCE). SOC Alarmdashboard built from scratch : banner+sound alerting, 15-category taxonomy, offline neural TTS voice announcements (14 voices), live system health bar (CPU/RAM/GPU/disk/network, MangoHud-styled), live active-connections panel with scan/VoIP/game highlighting.
07-18	SOC Alarmdashboard plan/architecture doc, CV, and a daily report added.
07-20	OPNsense-as-primary-router migration, all 4 phases, same day : Phase 0 (spare NIC cabled) + Phase 1 (tested rollback "KPN-terugval" panic button) → Phase 2 (OPNsense given the real WAN via macvtap) → Phase 3 (burn-in monitoring, found and fixed a real lab/home-network RFC1918 isolation gap) → Phase 4 (this host's own default route cut over to OPNsense). Real incident during Phase 4: <code>nmcli connection up virbr10</code> dropped every lab VM's bridge port; recovered, root-caused, and turned into a hard rule (<code>reapply</code> , never <code>up / down</code> , on that bridge) — see §7.9 . Alarmdashboard also grew substantially the same day: search bar, per-connection WHOIS/GeoIP/SYN-scan (authorization-gated), block-IP via a real OPNsense alias, kill-process, timed/permanent ban list, WAN-DDoS spike detection.

Period	What happened
07-21	KPN Box 14 confirmed unable to do bridge/modem-only mode (no separate modem exists on this fiber connection — the Box <i>is</i> the ONT). WiFi-behind-OPNsense scoped, then paused: the host's own WiFi (Intel AX210) is passed through to Kali <i>and</i> can't run AP mode on any OS regardless — needs dedicated AP hardware not yet sourced. Alarmdashboard: qBittorrent DDoS-spike exclusion extended to OPNsense's own WAN metric (Phase 4 meant it now sees this host's torrent traffic too); a dedicated P2P/Torrent alert category added and hidden from the feed/voice; a full false-positive triage system built — a local, rule-based, no-AI engine (signature knowledge base + known-daily-process correlation + timing correlation) running automatically on every new alert at ingestion , plus an on-demand periodic Claude Code check for novel cases, both gated by a hard never-touch list (Reverse Shell/Priv Esc/Exploit/Credential Access/Lateral Movement/Persistence/MITM/SQLi/XSS).

9. Asset inventory

Full detail: `Documents/ASSET_INVENTORY.md`.

Physical host

Property	Value
OS	Bazzite Linux
CPU	Intel Core i9-11900K (8c/1s)
GPU	NVIDIA GeForce RTX 3090
RAM	62 GiB
WiFi	Intel AX210 (Wi-Fi 6E)
Virtualization	KVM, QEMU, libvirt, virt-manager

Virtual machines

VM name (virsh)	IP	SSH	OS / role
OPNsense-FW	.1	opnsense /root	Firewall/gateway
DC01	.10	dc01 /Administrator	Windows Server 2022, AD DC, domain pentest.lab
WIN11-01	.20	win11-01 / pentest\administrator	Windows 11, domain-joined as DESKTOP-EFKB8GQ
SOC-SecurityOnion	.30	security-onion /socadmin	Security Onion 3.1.0 standalone
ubuntu-server-01	.40	ubuntu-server /sysadmin (key auth works)	Linux server, live Juice Shop on :3000
ATTACK-Kali	.50	kali /blue1	Red Team workstation
Target-Metasploitable2	.70	none	Vulnerable target, stock fingerprint

Active Directory identity inventory

OU	Accounts
Domain Controllers	DC01
Admins	IT Admin 01 (not in Domain Admins)
AD-Users	soctest, Helpdesk 01, Employee 01, Manager 01, HR 01, Finance 01
Service-Accounts	SQL Service
Workstations / Servers	(empty)

Custom groups: SOC-Analysts (soctest), Helpdesk (no members). Domain Admins = built-in Administrator only.

Software versions

Security Onion 3.1.0 · Elastic Agent 9.3.3+build202604082258 · Sysmon 15.21 (schema 4.91, SwiftOnSecurity config) · Windows Server 2022 Standard Evaluation (DC01).

Access methods (no passwords stored here)

SSH keys (~/.ssh/config) — passwordless for dc01/security-onion/kali/ubuntu-server/win11-01; password-only by design for opnsense. Browser session (Playwright, dedicated profile) for Security Onion/Kibana/Fleet, and a separate one for OPNsense (browser/launch-opnsense-daemon.mjs , port 9333). virsh -c qemu:///system for VM management.

Open items

- `opnsense` SSH password-only by design (confirmed via audit, not a regression) — key auth could still be added for convenience if desired.
- OPNsense's own config-revision history is empty (no built-in rollback safety net) and it hasn't checked for firmware updates since install — see `Documents/OPNSENSE_AUDIT_2026-07-13.md`.
- The `KALI` firewall alias in OPNsense still points at Kali's old IP (`.157`) — harmless (unused in any active rule) but worth cleaning up.
- ~~`ubuntu-server-01` SSH key login doesn't work~~ — resolved 2026-07-14, key auth confirmed working (user `sysadmin` , not `ubuntu`).
- ~~WiFi PCI passthrough to Kali not reconfirmed~~ — reconfirmed 2026-07-21: the AX210 is VFIO-passed to `ATTACK-Kali` for wireless-pentest work, and separately confirmed it can't run AP mode on any OS regardless (hardware/firmware limit) — so it wouldn't be usable for the deferred WiFi-behind-OPNsense project even if reassigned. Stays with Kali.
- WIN11-01's intended training purpose — see [§12](#).
- WiFi-behind-OPNsense segmentation needs dedicated AP hardware (new purchase or a repurposed old router) — scoped and paused 2026-07-21, see `Documents/decisions/architecture_decisions.md`.

10. Glossary

Active Directory (AD) — Microsoft's user/computer/permission management system ("domain"). Runs on DC01; domain `pentest.lab`.

Agent — a program collecting/forwarding data (logs, metrics) to a central system (see Elastic Agent).

Beats — Elastic's lightweight data shippers; run inside Elastic Agent in modern deployments.

CEST/CET — Central European (Summer) Time; UTC+1 winter, UTC+2 summer.

Dead Letter Queue (DLQ) — where Logstash puts documents it couldn't store in Elasticsearch. A growing counter signals a downstream problem even without a sender-side error.

Domain Controller (DC) — AD server managing users/computers. Here: DC01.

Elastic Agent — collects Windows Event Logs/Sysmon/metrics on DC01 and ships to Security Onion; multiple components, each with its own health status.

Elastic Defend — Elastic Agent's endpoint-security (EDR) component; own Fleet connection (port 3765, hostgroup `endgame`).

Elasticsearch — Security Onion's log database; always UTC-internal.

Firewall hostgroup/portgroup — [§5.4](#). Hostgroup = named IP group, portgroup = named port group; Security Onion's firewall links them.

Fleet / Fleet Server — Kibana/Elastic's agent-management layer; server side runs on Security Onion, port 8220.

Hunt — Security Onion's own search UI (like Kibana Discover).

KVM/QEMU/libvirt — this lab's virtualization stack (kernel tech / hardware emulation / management layer).

NTP — clock-sync protocol; DC01 uses `pool.ntp.org`.

PDC Emulator — AD role: normally the domain's authoritative time source. DC01 holds it (the lab's only DC).

Security Onion — this lab's SOC platform (Suricata, Zeek, Elasticsearch, Kibana, Fleet). VM `SOC-SecurityOnion`, .30.

SIEM — collects/correlates logs across sources to find incidents. Security Onion is this lab's SIEM.

Sigma rule — general-purpose log detection rule format (Suricata's equivalent for network traffic).

so-firewall — CLI for Security Onion's own firewall (hostgroup membership). [§5.4](#).

Sysmon — Sysinternals tool logging detailed Windows events far beyond the standard Event Log. On DC01 since 2026-07-13, SwiftOnSecurity config.

UTC — global time standard, no offset. Elasticsearch always stores UTC internally.

vmctimesync — hypervisor clock-sync service (Hyper-V-compatible, also active under QEMU/KVM). Disabled on DC01 — was overriding NTP at boot.

Zeek (formerly Bro) — records network activity (DNS, HTTP, TLS, connections); complements Suricata's attack-pattern focus.

11. Current project status / what's next

Full detail: `Documents/PROJECT_STATUS.md`.

Done

Base infrastructure (all 7 VMs on `pentest-lab`) · event-driven traffic mirroring · AD operational · Security Onion operational (web UI, Kibana, Fleet, Hunt) · DC01 Healthy in Fleet, survives restarts/reboots · passwordless SSH to `security-onion/kali/dc01` · six desktop launchers · read-only web-audit script · this documentation structure · live network/asset/AD verification pass (2026-07-13) · read-only OPNsense configuration audit (2026-07-13) · Elastic Agent on the Bazzite host itself, Healthy, confirmed reboot-survival, plus a central health-check script covering it and all 7 lab VMs (2026-07-14) · SSH access to WIN11-01 (2026-07-14) — OpenSSH Server enabled, integrated into `~/ .ssh/config` and `lab-ssh-all.sh / soc-health-check.sh`, giving it the same admin path as the other lab systems · Elastic Agent + Sysmon on WIN11-01 (2026-07-14) — Healthy in Fleet, Elastic

Defend/osquery/winlog/Sysmon/metrics all confirmed, telemetry verified in Hunt; endpoint-monitoring priority 1 of Documents/ROADMAP_ENDPOINT_MONITORING.md done · Elastic Agent on ubuntu-server-01 (2026-07-14) — Healthy in Fleet, log/metrics-only, telemetry verified in Hunt; priority 2 done · ubuntu-server-01's long-standing .100 -drift DHCP bug root-caused and fixed (2026-07-14) — see Documents/troubleshooting/12_ubuntu-server-01_dhcp_reservation_fix.md · endpoint-monitoring phase fully closed (2026-07-15) — Kali will deliberately not get an Elastic Agent, Joost's final decision, not deferred · Phase 3 Tier 1 (recon) fully validated in Hunt (2026-07-15), see §6.3 · SOC Alarmdashboard (2026-07-15) — live local banner+sound alerting on the Bazzite host per attack type, see Documents/guides/alarm_dashboard.md · **OPNsense-as-primary-router migration, all 4 phases complete (2026-07-20)** — this host's own default traffic now routes through OPNsense (not just the lab's), with a tested one-action rollback ("KPN-terugval" panic button) if it ever needs undoing; real incident during the cutover (§7.9) found, fixed, and turned into a standing hard rule · Alarmdashboard grown substantially (2026-07-20/21): search bar, per-connection WHOIS/GeolP/authorization-gated SYN-scan, block-IP via a real OPNsense alias, kill-process, timed/permanent ban list, WAN-DDoS spike detection (on both this host's and OPNsense's own WAN, both with a qBittorrent exclusion) · **false-positive triage system** (2026-07-21) — a local, rule-based, no-AI engine (signature knowledge base + known-daily-process correlation + timing correlation) that now runs automatically on every new alert at ingestion, plus an on-demand periodic Claude Code check for novel cases; hard-gated so Reverse Shell/Priv Esc/Exploit/Credential Access/Lateral Movement/Persistence/MITM/SQLi/XSS alerts are never auto-dismissed · KPN Box 14 bridge-mode capability investigated and closed out (2026-07-21) — not supported on this fiber connection, confirmed via KPN's own community forum, documented as a permanent constraint rather than a pending task.

Open

Security Onion OS-level timezone still UTC (cosmetic, blocked on root scope) · AD structural gaps (empty Helpdesk group, IT Admin 01 not elevated, undifferentiated role accounts, empty Workstations / Servers OUs) — **to be deliberately fixed as part of §12**, not left as-is · the full §12 test pass, AD escalation-path build, and WIN11-01 cleanup are scoped and agreed but **not yet executed** — pre-change snapshots already taken (DC01 : 2026-07-13-pre-ad-escalation-path , WIN11-01 : 2026-07-13-pre-target-cleanup) · the Bazzite host's own Elastic Agent's log delivery is now verified end-to-end into Elasticsearch (see Documents/troubleshooting/08_bazzite_host_elastic_agent.md), but not yet re-confirmed across a reboot cycle · WiFi-behind-OPNsense segmentation is scoped but blocked on sourcing dedicated AP hardware (the host's own WiFi can't be reused — see §9 Open items) · the periodic false-positive triage CronCreate job is session-only (dies when the current Claude Code session ends, auto-expires after 7 days regardless) — not a 24/7 watcher, by deliberate choice (see Documents/decisions/architecture_decisions.md).

Planned

Detection engineering confirmation (§6.3, Tier 1 done, Tier 2/3 pending approval, Tier 2 vsftpd test already run 2026-07-15) · combined host/security/gaming dashboard · four-tier alerting (INFO/WARNING/HIGH/CRITICAL) with Discord/Telegram forwarding — **note:** a *different*, attack-type-categorized local dashboard now exists (Documents/guides/alarm_dashboard.md), this severity-

tier/external-forwarding design remains separately unbuilt · WiFi-behind-OPNsense segmentation, pending AP hardware · VLAN segmentation, separate mgmt/attack networks, additional Windows clients, honeypots, periodic Purple Team exercises.

Keeping this current

Every important change: update the specific source doc → `CHANGELOG.md` → `Documents/PROJECT_STATUS.md` → a daily report in `Documents/daily/` → this master document.

12. Attack scope: agreed Red Team test plan

Scope agreed with Joost 2026-07-13; execution deliberately deferred to a dedicated session.

Grounded in the live-verified lab state above — nothing generic. Everything stays inside `192.168.50.0/24`, launched from Kali, against only the lab's own systems.

Agreed order:

1. **Tier 1 + 2 together, first** — recon/enumeration plus exploitation of the intentionally-vulnerable targets (Metasploitable2, Juice Shop). Low risk, closes most of §6.1's ⚠ rows.
2. **AD attack chain (Tier 3) — build the escalation path first.** The environment currently has none (IT Admin 01 isn't a Domain Admin). Before Kerberoasting/privilege-escalation practice: set an SPN on SQL Service, give IT Admin 01 real elevated rights. This is an infrastructure change — full change procedure (§4), its own explained/confirmed step, not bundled into the attack.
3. **WIN11-01 becomes a target too, after cleanup** — move DESKTOP-EFKB8GQ into OU=Workstations, general tidy-up, then deliberately loosen its firewall for lateral-movement testing (WIN11-01 → DC01).

Preparation already done: pre-change snapshots (DC01 : 2026-07-13-pre-ad-escalation-path, WIN11-01 : 2026-07-13-pre-target-cleanup). Tier 1 (recon) fully executed and validated 2026-07-15 (§6.3). Tier 2 explicitly approved by Joost 2026-07-15 and started the same day — vsftpd 2.3.4 backdoor exploitation against Metasploitable2 done (real root RCE, nuanced detection result, see §6.3), three scenarios remain. **AD changes and firewall changes (Tier 3) remain not executed**, still pending separate explicit approval.

Tier 1 — Reconnaissance & enumeration

Scenario	Target	Technique
Full port/service scan	Metasploitable2 (.70)	<code>nmap -sV -sC -p-</code>
Web app recon	Juice Shop (.40:3000)	<code>nikto</code> , <code>gobuster</code> / <code>ffuf</code>
AD/domain enumeration	DC01 (.10)	<code>enum4linux-ng</code> , <code>netexec smb</code> , anonymous LDAP
Network sweep	<code>.0/24</code>	<code>nmap -sn</code>

Tier 2 — Exploitation of intentionally-vulnerable targets

Scenario	Target	Technique	Status
vsftpd backdoor	Metasploitable2:21	<code>vsftpd_234_backdoor</code> (repeats the historical exploit, §8)	✅ Done 2026-07-15, root RCE confirmed, see §6.3
Samba/NFS/RMI	Metasploitable2	<code>usermap_script</code> , anonymous NFS mount, Java-RMI deserialization	⌚ Not yet run
OWASP Top 10	Juice Shop	SQLi, broken auth, IDOR, XSS — built-in scored challenges	⌚ Not yet run
UnrealIRCd backdoor	Metasploitable2:6667	Known backdoor trigger	⌚ Not yet run

Tier 3 — Active Directory attack chain (after the escalation-path build)

Scenario	Target	Technique
Password spraying	DC01	Common passwords, low attempts/account
Kerberoasting	DC01	TGS request for <code>SQL Service</code> , crack offline (needs the SPN)
AS-REP roasting	DC01	Needs an account with Kerberos pre-auth disabled (none exists yet)
Lateral movement	WIN11-01 → DC01	From an assumed foothold — worth testing against the current locked-down firewall first
Golden/Silver ticket	DC01	Capstone — needs prior privileged access

Execution checklist: Tier 1+2 → cross-check Hunt, flip §6.1 statuses → build the AD escalation path (explained/confirmed) → clean up WIN11-01, loosen its firewall → run Tier 3 + lateral movement → update §6.1/§11 with results.

Document index

Root: `README.md`, `LAB_OVERVIEW.md`, `PROJECT_RULES.md`, `AI_ACCESS_POLICY.md`, `NETWORK.md`, `SERVERS.md`, `SECURITY.md`, `ACTIVE_DIRECTORY.md`, `CHANGELOG.md`. Documents/: `INDEX.md`, `ASSET_INVENTORY.md`, `GLOSSARY.md`, `PROJECT_STATUS.md`, `OPNSENSE_AUDIT_2026-07-13.md`, `ROADMAP_ENDPOINT_MONITORING.md`, `PHASE1_CLOSURE_SUMMARY.md`, `ROADMAP_OPNSENSE_LOGGING.md` (Phase 2A — Firewall + DHCP syslog forwarding, validated 2026-07-15), `ROADMAP_PHASE2B_DNS_QUERY_LOGGING.md` (Unbound query logging, deliberately deferred 2026-07-15), `decisions/*.md`, `guides/*.md` (12 files, incl. `alarm_dashboard.md`),

troubleshooting/01 – 12 , chat_history/*.md (6 files), daily/*/ , screenshots/ , plus committed personal artifacts: dagrapporten-pdf/ , CV Cybersecurity.pdf , soc-alarmdashboard-plan-en-architectuur.md .

Single Documents/ folder (2026-07-22): the former docs/ (technical documentation) and Documents/ (personal artifacts) were merged into one Documents/ folder — the case-different pair was confusing on GitHub. pentest.lab - by Joost Hebly.md (repo root), an earlier unmerged concatenation of the same sources that this document had already superseded, was removed from the repo in the same pass (still recoverable from git history).

Job-application material policy: CVs and motivation letters per company are deliberately kept out of the public repo — they live locally in ~/Documents/Sollicitaties/<Bedrijf>/ , outside the git working tree. A per-application example (Documents/sollicitaties/WhiteHats/) was briefly committed on 2026-07-21 and removed on 2026-07-22 once this was flagged as a privacy concern; it remains recoverable from git history unless that history is later rewritten.